Explainable Cyber-Insurance Underwriting and Continuous Warranty Monitoring for Indian SMEs

Harsh Rathod
MPSTME, SVKM's NMIMS
Mumbai, India

Yugandhara Raj Goud
MPSTME, SVKM's NMIMS
Mumbai, India

Krish Mundhra
MPSTME, SVKM's NMIMS
Mumbai, India

Rohit Suryawanshi
MPSTME, SVKM's NMIMS
Mumbai, India

***Abstract*—Indian small and medium enterprises (SMEs) buy little cyber insurance, and the cover they can buy is usually priced from a self-completed questionnaire that nobody checks again until renewal. The insured sees one figure and cannot tell which answer raised it. This paper presents Beretta, an open prototype that links evidence, pricing, binding and post-bind monitoring in one inspectable pipeline. Evidence for each security control is graded on a four-level ladder from DECLARED to TECHNICALLY_OBSERVED. A frequency-severity engine then prices five perils with lognormal severity, multipliers derived from published claims data, Bühlmann-style claims credibility and a target loss ratio. Each parameter carries its source and a tag that marks it as literature, derived or assumption. After bind, a read-only agent running 12 checks sends signed reports to a collector, which pushes one signed roll-up per company to the platform. Monitoring moves warranty states and never changes the bound premium. For a reference firm, the technical premium is ₹46,487 with all controls verified, ₹55,342 with all stated and ₹2,48,235 with none evidenced. All 224 automated tests pass, including a cross-system test that shows an unchanged premium through a warranty failure and recovery on simulated endpoints. The parameters come mainly from US-weighted claims books with no India adjustment, so the premiums are not actuarially validated rates.**

***Index Terms*—cyber insurance, premium modelling, frequency-severity model, lognormal severity, credibility theory, explainable underwriting, continuous monitoring, warranty, Indian SMEs**

I. Introduction

Cyber insurance transfers part of the financial loss from a security incident to an insurer. Take-up among smaller firms is low: a 2025 GlobalData survey of 2,054 SMEs in 14 countries found 16.8% with a standalone policy [1]. In India, the Digital Personal Data Protection Act, 2023 [2] and the CERT-In Directions of 2022 [3], which set a six-hour window for reporting specified incidents, have raised the cost of handling an incident without giving SMEs a clearer way to judge the cover on offer.

Published work points to three problems with how this cover is priced and maintained. Filed US policies show that carriers often price on revenue and industry, with limited technical detail [4]. Proposal forms ask whether a control exists and rarely how it was verified [5]. When an insurer cannot observe security, insurance can reduce the effort that firms put into it [6]. A control can also fail the week after bind, and without monitoring the gap appears only at claim time.

Monitoring-linked cyber insurance already exists commercially, for example at Coalition and At-Bay, but their pricing models are not published. This paper adds an open pipeline in which any number, from evidence to warranty state, can be traced to its source and reproduced. Its contributions are:

- A four-level evidence ladder that sets how much premium credit a control earns, so that a questionnaire "yes" and an observed pass are priced differently.
- A five-peril frequency-severity model built on published claims data, with a provenance tag on every parameter and a list of the assumptions used in each quote.
- A signed, read-only monitoring chain from endpoint agent through collector to platform, built with the Python standard library only.
- A warranty state machine separated from pricing, so that post-bind monitoring cannot re-price a bound policy. Tests enforce this rule.

Section II reviews related work. Section III gives the methodology and Section IV the pipeline diagrams. Section V reports the results, Section VI covers advantages, limitations and applications, and Section VII concludes.

II. Background and Related Work

A. Surveys and Market Models

- Böhme and Schwartz [7] give a framework for classifying market models of cyber insurance.
- Marotta, Martinelli, Nanni, Orlando and Yautsiukhin [8] survey the scientific approaches to analysing the cyber-insurance market and set out directions for further research.
- Shetty, Schwartz, Felegyhazi and Walrand [6] show that insurance can lower security effort when insurers cannot observe it, which motivates observing controls before and after bind.
- Pal, Golubchik, Psounis and Hui [9] find that insurance improves network security only when contracts discriminate by security level. In Beretta, firms of the same sector and turnover pay differently when their evidenced controls differ.

B. Insurance Pricing and Loss Models

- Maillart and Sornette [10] show that the sizes of personal-data breaches are heavy-tailed, so rare events dominate the average. The payout calculation here therefore integrates over the whole loss distribution through the retention and limit.
- Edwards, Hofmeyr and Forrest [11] fit breach sizes with a lognormal and breach counts with a negative binomial. Severity here uses the first form, and the credibility parameter is derived from the second.

- Biener, Eling and Wirfs [12] analyse 994 cyber losses from an operational-risk database and discuss whether the risk is insurable.
- Eling and Loperfido [13] test the goodness of fit of breach-loss distributions and apply the results to pricing and risk measurement.
- Eling and Wirfs [14] study actual cost data across a broad range of cyber risk events.
- Xu and Hua [15] price cyber insurance from an epidemic model, a loss function and a premium strategy, computing the premium by simulation.
- Zeller and Scherer [16] model targeted attacks, untargeted attacks and accidents with marked point processes and apply the model to pricing and risk measurement.
- Bessy-Roland, Boumezoued and Hillairet [17] use a multivariate Hawkes process for the frequency of cyber attacks. Clustering is not modelled here (Section VI-B).
- Xiang, Neufeld, Peters, Nevat and Datta [18] link premiums to security provisioning through a bonus-malus design. Here the premium is set at inception and stays fixed for the term.
- Bühlmann [19] sets out credibility theory, in which a firm's own experience is weighed against the collective rate. The claims multiplier in Section III-F takes this form.
- Klugman, Panjer and Willmot [20] give the standard treatment of severity models, coverage modifications and limited expected value. The numerical payout is checked against that closed form.

C. How Carriers Underwrite in Practice

- Romanosky, Ablon, Kuehn and Jones [4] analyse US regulatory filings and find wide variation in how far pricing goes beyond size and industry.
- Woods, Agrafiotis, Nurse and Creese [5] compare 24 proposal forms with security frameworks and discuss the gaps between them, which motivates the evidence ladder.
- Nurse, Axon, Erola, Agrafiotis, Goldsmith and Creese [21] use focus groups with practitioners to examine the data used in underwriting and claims, and the gaps in that data.
- Mott, Turner, Nurse, MacColl, Sullivan, Cartwright and Cartwright [22] draw on 96 professionals and identify ransomware as a driver of market hardening.
- Woods and Simpson [23] set out where insurers can act: at application, in premium and conditions, and after bind. The Beretta pipeline follows those stages.
- Woods and Moore [24] ask whether insurance can deliver cybersecurity governance through private-sector means.

D. Monitoring and Explainability

- Dambra, Bilge and Balzarotti [25] classify earlier research and list practical problems at each insurance phase where system-security measurement can replace qualitative methods. The agent and collector here are one attempt at this.
- Dempsey, Chawla, Johnson, Johnston, Jones, Orebaugh, Scholl and Stine [26] define continuous monitoring as ongoing awareness of security state to support risk decisions.
- Doshi-Velez and Kim [27] argue for interpretability where a decision must be justified. Each factor in the premium here is named and visible in the quote.

E. Research Gap

Table I compares the reviewed work on the four properties that Beretta combines. No class of work reviewed here has all four in open form.

TABLE I
COVERAGE OF THE FOUR PROPERTIES BY CLASS OF WORK

Class of work	Prices from claims data	Grades evidence	Monitors after bind	Open to inspection
Actuarial loss models [10], [11], [15], [16], [17]	Yes, mostly breach or incident data	No	No	Method published
Studies of filings and forms [4], [5], [21]	Describe practice	Identify the need	No	Yes
System-security roadmap [25]	No	Proposed direction	Proposed direction	Yes
Commercial monitoring-linked insurers	Not published	Not published	Yes	No
Beretta (this paper)	Yes	Yes	Yes, warranties only	Yes

III. METHODOLOGY

A. Design Rules

Three rules constrain the method. First, the system has two linked parts: the platform owns premiums and warranties, and the monitoring system owns everything about endpoints. Second, monitoring never re-prices a bound policy: the engine refuses such a request and every roll-up response reports repricing_performed as false. Third, the code uses only the Python standard library and plain HTML, CSS and JavaScript, so that each calculation can be read without third-party code. Every model value is stored in one parameter file with its value, unit, source, locator and a tag: [L] taken from a published source, [D] derived from [L] values by a script, or [A] an assumption with a sensitivity range.

B. Evidence Assessment (Engine A)

Each input becomes an observation that records the control, its value, the evidence strength, a source locator and timestamps, along with whether the control exists, is current and has been tested. Strength runs from DECLARED through DOCUMENTED and TESTED to TECHNICALLY_OBSERVED. For each control the strongest observation wins and ties go to the most recent; sources that disagree raise a conflict flag. The resolved result is read as one of four pricing statuses, shown in Table II.

TABLE II
PRICING STATUS OF A CONTROL

Status	When it applies	Multiplier
VERIFIED	Agent, fleet or outside-in pass; a tested artefact such as a restore test; an independent document such as SOC 2 Type II	m_{has}
STATED	Questionnaire "yes", self-assessment or self-authored policy; a partial result	$1 - x(1 - m_{has})$, $x = 0.6$
NOT_WORKING	Agent, fleet or scan failure; questionnaire "no"	m_{lacks}
UNKNOWN	No evidence	m_{lacks}

Pricing UNKNOWN at the same level as NOT_WORKING means that a firm cannot lower its premium by withholding an answer.

C. Claim Frequency by Peril

Risk is split into five perils p: ransomware, business email compromise (BEC), funds transfer fraud (FTF), other first-party and third-party liability. The frequency of each is

$$\lambda_p = \lambda_{p,global} \times R_{turn,f} \times R_{sec,f} \times F_{india,p} \times M_{ctrl,p} \times M_{claims} \quad (1)$$

Base frequencies and mean losses come from the Coalition 2025 report [28] (Table III). The five perils sum to 1.38%, and adding the "other" claims gives 1.47% against the 1.48% global rate in that source. Turnover relativities come from four bands: 1.07% below USD 10 million, 1.19% for USD 10 million to 25 million [29], 3.99% for USD 25 million to 100 million and 5.97% above that [28], with mean losses of USD 79,000, 79,000, 139,000 and 228,000. The National Industrial Classification (NIC) 2008 division selects the sector relativity [28], [29], [30]; a code that cannot be mapped is priced at the global average. The India factor $F_{india,p}$ and its severity counterpart S_{india} are kept as parameters and set to 1.

TABLE III
PERILS, WITH 2024 GLOBAL VALUES [28]

Peril	Base frequency $\lambda_{p,global}$	Mean loss m_p (USD)
Ransomware	0.31%	292,000
Business email compromise	0.44%	35,000
Funds transfer fraud	0.44%	185,000 (before clawbacks)
Other first-party	0.17%	49,000
Third-party liability	0.02%	23,000

To avoid a price cliff at a band boundary b, values within a factor of 1.25 of it move log-linearly from the lower band value f_{lo} to the upper value f_{hi}:

$$f(R) = f_{lo} \left(f_{hi} / f_{lo}\right)^{\ln(R / (b / 1.25)) / \ln(1.25^2)} \quad (2)$$

D. Severity and Policy Payout

Loss X_p is lognormal, the form supported by Edwards, Hofmeyr and Forrest [11], with a scaled mean and a shared shape parameter:

$$\text{mean}_p = m_p \times R_{turn,s} \times R_{sec,s} \times S_{india}$$
$$\mu_p = \ln(\text{mean}_p) - \sigma^2 / 2 \quad (3)$$

The value $\sigma = 2.193$ [D] solves mean = $\exp(\mu + \sigma^2/2)$ = USD 264,000 and P(X > USD 1 million) = 395/8,936 for SMEs in NetDiligence 2025 [30]. The equation has two roots. This root predicts P(X > USD 500,000) = 8.26% against the observed 8.24%, while the other root, $\sigma = 1.214$, predicts 12.86% and is rejected. IRIS 2025 [29] gives about 1.97, used as the low sensitivity value.

Each loss is split across coverage heads h in shares $s_{p,h}$ and passes through the retention d and the overall limit L. With $M_{sev,p,h}$ as the severity control multiplier, the expected payout per claim is

$$\text{payout}_p = E[\ \min(\ \Sigma_h\, s_{p,h}\, M_{sev,p,h}\, (X_p - d)_+,\ L\ )\ ] \quad (4)$$

The expectation is integrated on a quantile grid of 20,000 points below the 99th percentile and 4,000 above it. A closed-form limited expected value [20] checks the grid; for one head with a share of 1, the payout must equal LEV($d + L$) − LEV(d), where

$$\text{LEV}(u) = \exp(\mu + \sigma^2/2)\ \Phi((\ln u - \mu - \sigma^2)/\sigma) + u\ (1 - \Phi((\ln u - \mu)/\sigma)) \quad (5)$$

E. Control Multipliers

For a control with relative risk S (incident rate without the control divided by the rate with it) and adoption p, the multipliers are centred so that the average firm sits at 1:

$$m_{has} = 1 / (p + (1 - p)S), \quad m_{lacks} = S / (p + (1 - p)S) \quad (6)$$

Each is capped to [0.5, 2.0] [A]. Frequency values come from Marsh McLennan [31], as shown in Table IV. Severity controls use the same formula: tested backups with $S = 8.0$ and $p = 0.43$ from Sophos [32]; incident-response plans and the severity part of awareness training with $S = 1.055$ [33]; encryption with $S = 1.101$ [34]. Their adoption values of 0.5 are placeholders [A]. Meyer, Romero, Bertoli, Burt, Weinert and Ferres [35] support MFA as an effective control, but the MFA adoption value in Table IV is an assumption awaiting a source.

TABLE IV
FREQUENCY CONTROLS [31]

Control	S	p	Attack stage; perils
Secure configuration	5.58	0.96	Weakness; ransomware, other first-party
Privileged access management	2.92	0.35	Execution; ransomware, other first-party
Endpoint detection and response	2.23	0.82	Execution; ransomware, other first-party
Logging and monitoring	2.19	0.88	Execution; ransomware, other first-party
Vulnerability management, high CVEs ≤ 7 days	2.19	0.24	Weakness; ransomware, other first-party
Critical patching, critical CVEs ≤ 7 days	1.57	0.53	Weakness; ransomware, other first-party
Awareness, phishing simulation at least yearly	1.76	0.89	Credential; ransomware, BEC, FTF
Email security, attachment sandboxing	1.56	0.75	Credential; ransomware, BEC, FTF
Multi-factor authentication	1.4	0.70 [A]	Credential; ransomware, BEC, FTF

Marsh measured S on declared controls, some of which may not work. If a share f of declarations are hollow, a declaration earns only part of the true credit. Averaged over the Marsh controls this gives $x = 0.81$, 0.62 and 0.43 for $f = 0.1$, 0.2 and 0.3, and the model uses $x = 0.6$ with $f = 0.2$ as the assumed base. Controls defending the same attack stage overlap, so within a stage the multipliers are sorted by $|\ln m|$ and damped with $\beta = 0.5$ [A]:

$$\ln M_{\text{stage}} = \Sigma_k \beta^k \ln m_k \quad (7)$$

Stage results multiply across stages, and the combined value is clamped to [0.27, 3.0]. The floor reflects Coalition's report of 73% fewer claims among its policyholders, and the ceiling reflects about three times the claims with end-of-life software [28].

F. Claims Credibility

Following credibility theory [19], a firm with N material incidents over $T = \min(3, \text{years in operation})$ receives

$$M_{\text{claims}} = (\alpha + N) / (\alpha + \lambda_{\text{firm}} T) \quad (8)$$

The parameter $\alpha = 4.22$ [D] is derived from a negative-binomial fit to IRIS 2022 [36], after removing the heterogeneity already explained by controls and sector. It applies equally to every peril. The derivation depends on the frequency basis: the ransomware basis gives 4.22 and the all-peril basis about 1.6, so a real book's experience should check it.

G. Premium, Gate and Explanation

Expected loss sums over perils, and the premium divides it by a target loss ratio (TLR):

$$\text{EL} = \Sigma_p \lambda_p \times \text{payout}_p$$

$$\text{Technical premium} = \text{EL} (1 + \text{trend}) / \text{TLR} \quad (9)$$

The TLR of 0.50 sits between Fitch's nine-year US standalone average of 48% [37] and the 57% in the NAIC 2026 report [38]. The breakdown shows 50% expected loss, 30% expenses, matching the IRDAI cap for general insurers [39], and 20% for profit, risk margin, reinsurance and accumulation. Trend is 0 [A]. GST at 18% is added as a separate line.

Four controls are warranties: MFA, tested backups, EDR and critical patching. A warranty that is NOT_WORKING or UNKNOWN blocks binding, a warranty that is STATED makes the quote conditionally eligible (MFA may remain stated because the platform cannot verify it), and neither outcome changes the price. Referral to an underwriter is triggered by turnover above USD 2 billion, a multiplier at the 3.0 ceiling, two or more material incidents, or RBI or SEBI regulation. Each quote stores the full factor breakdown, the [A] values used, a what-if list of savings from verifying each control, and a snapshot of inputs and parameters from which the same premium can be reproduced.

H. Monitoring: Agent, Collector and Link

The agent runs the 12 checks listed in Table V. It is read-only and does not collect file contents, browsing data, keystrokes, e-mail, passwords or clear-text user names. Reports carry a sequence number, the build hash and the policy hash, and are signed with HMAC-SHA256 [40] under a per-agent secret. An outbox holds them while the machine is offline.

TABLE V
THE 12 AGENT CHECKS

Tier	Check	Platform control
Warranty	Security updates within 7 days	CTRL-PATCH-CRIT
Warranty	EDR running and healthy	CTRL-EDR
Warranty	Recent backup success (sent as partial)	CTRL-BACKUP-TESTED
Warranty	MFA at the identity provider (not observable from a host, never sent)	CTRL-MFA
Important	Disk encryption	CTRL-ENCRYPTION
Important	Host firewall; exposed services; remote access hardening; OS vendor support	CTRL-SECCONFIG
Important	Local administrator accounts	CTRL-PAM
Regulatory	Log retention; time synchronisation	CTRL-LOGGING

The collector authenticates before it parses: it checks the agent and signature, then the schema, a sequence number higher than the last one, a five-minute limit on future clock skew, a 30-day limit on report age, and whether the build and policy hashes are approved. A host that has not reported for 6 hours is UNVERIFIED and after 72 hours it is SILENT. A silent host with a last result of FAIL keeps counting as a failure, so that silence cannot hide one. A control passes across the fleet when 95% of observed hosts pass it, and the separate coverage requirement is that at least 90% of declared endpoints report. These thresholds are demonstration assumptions.

The collector then maps its results to platform controls, where any failing source fails the platform control, and pushes one HMAC-signed, sequenced roll-up per company on each change and every 15 minutes. The platform checks the signature, sequence, timestamp and company link, and records each result as AGENT_FLEET evidence at TECHNICALLY_OBSERVED strength. Exact repeats within 6 hours are skipped.

I. Warranty State Machine

At bind, each warranty starts at MET. A failing observation moves it to IN_GRACE, with 7 days for MFA, backups and EDR and 14 days for patching and monitoring coverage. If the grace period expires it moves to BREACHED, and the configured coverage consequence may apply. A passing observation moves it to REMEDIATED and then back to MET. The consequences are illustrative, and the interface labels them as a prototype evaluation that is subject to policy wording and claims handling. The platform is the only warranty authority for linked companies; the collector displays the platform's states.

J. Evaluation Design

The system has no claims experience, so loss prediction cannot be measured. The evaluation instead checks internal correctness and model behaviour, in four steps: (a) the automated test suites; (b) a reference firm priced under controlled changes to one input at a time; (c) one-at-a-time

sensitivity of every assumption; and (d) one cross-system run over simulated endpoints. The reference firm is an IT services company (NIC 62) with a turnover of ₹150 crore, 10 years in operation, no material incidents, an overall limit of ₹5 crore and a retention of ₹5 lakh. All results come directly from the engine.

K. Standards Applied

We mapped the design and test work to the standards below after building the system. No third party has audited the project for conformance.

- IEEE Std 1016-2009 [41] defines design viewpoints, and the project's diagrams cover seven of them: context (use case and context data flow), composition (component), logical (class), information (entity-relationship), interaction (sequence), state dynamics (state machine) and algorithm (activity). IEEE has listed this standard as inactive-reserved since March 2020.
- ISO/IEC/IEEE 29119-1:2022 [42] describes test levels. The parser, verdict, agent-core and pricing suites work at unit level, the collector, platform and fleet-link suites at integration level, and the HTTPS end-to-end and cross-system tests at system level. There has been no acceptance testing with an insurer or an insured firm.
- IEEE Std 754-2019 [43] defines the binary64 format of the Python floats in which the pricing engine does its arithmetic.
- Agent reports and platform roll-ups are signed with HMAC [40] over SHA-256 [44]. The agent and the collector server require TLS 1.2 or later [45].

IV. Pipeline Diagrams

Fig. 1 shows the end-to-end pipeline. The fleet observation has two routes: before bind it feeds Engine A for the next quote, and after bind it reaches only the warranty state machine. The dashed line marks the route that does not exist.

Fig. 2 shows how Engine A turns raw inputs into one pricing status per control and keeps the source trail for display. Fig. 3 shows the eight pricing steps of Engine B, corresponding to (1) to (9). Gate and referral outcomes branch off at the end and do not feed back into the price. Fig. 4 follows one result from an endpoint to the platform, with signature and sequence checks at both the collector and the platform. Fig. 5 shows the warranty states, none of which changes the bound premium.

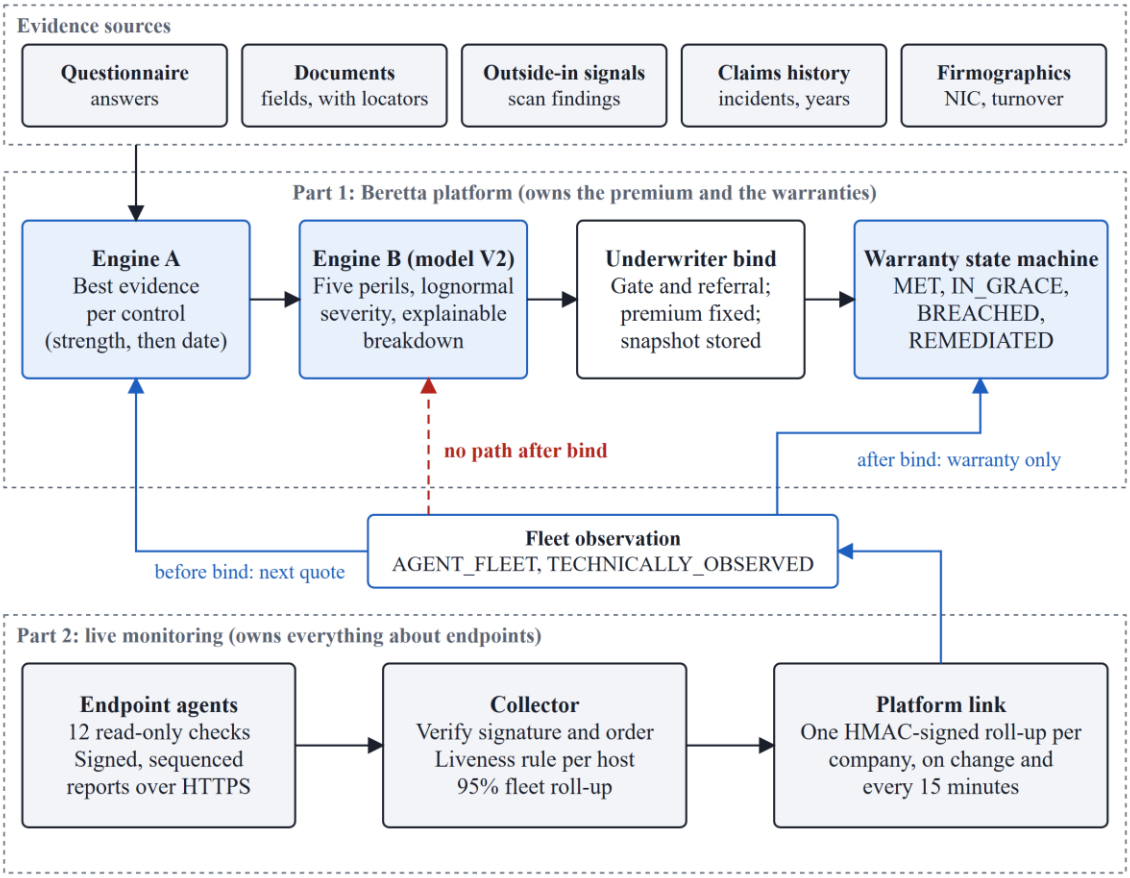


Fig. 1. End-to-end Beretta pipeline across Part 1 and Part 2

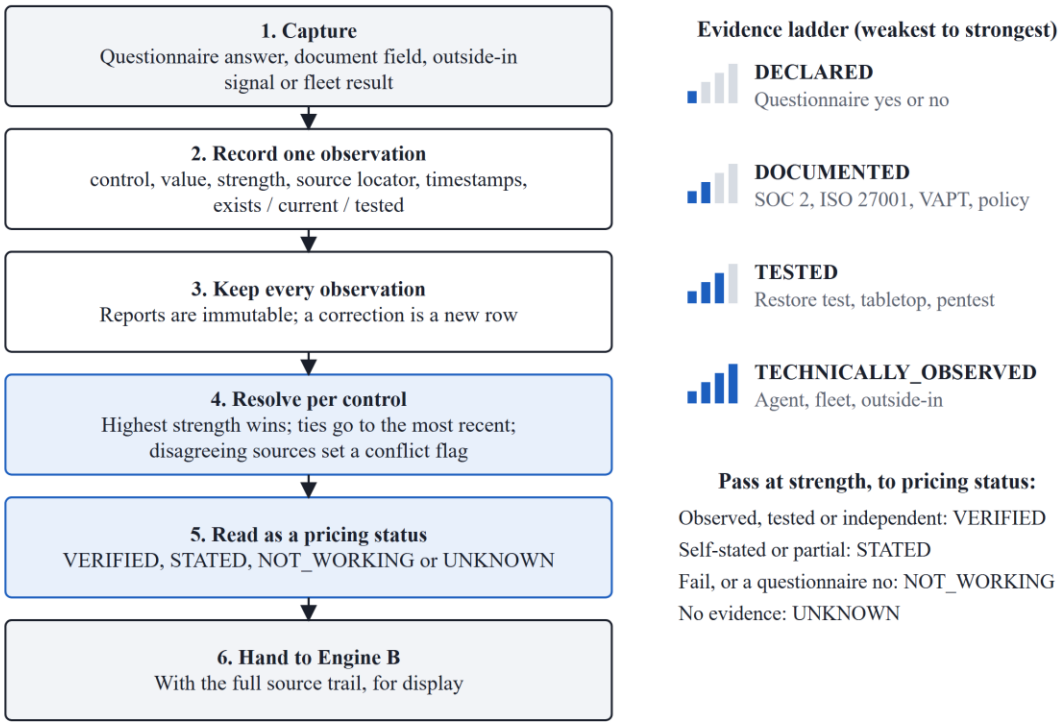


Fig. 2. Engine A: evidence assessment pipeline and evidence ladder

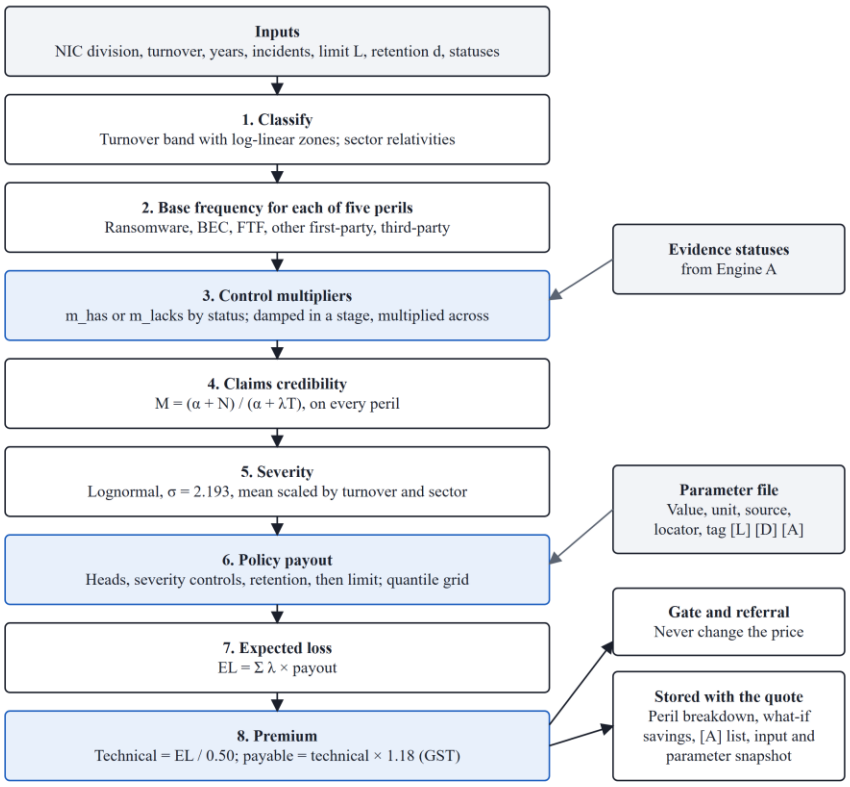


Fig. 3. Engine B: premium pricing pipeline (model V2)

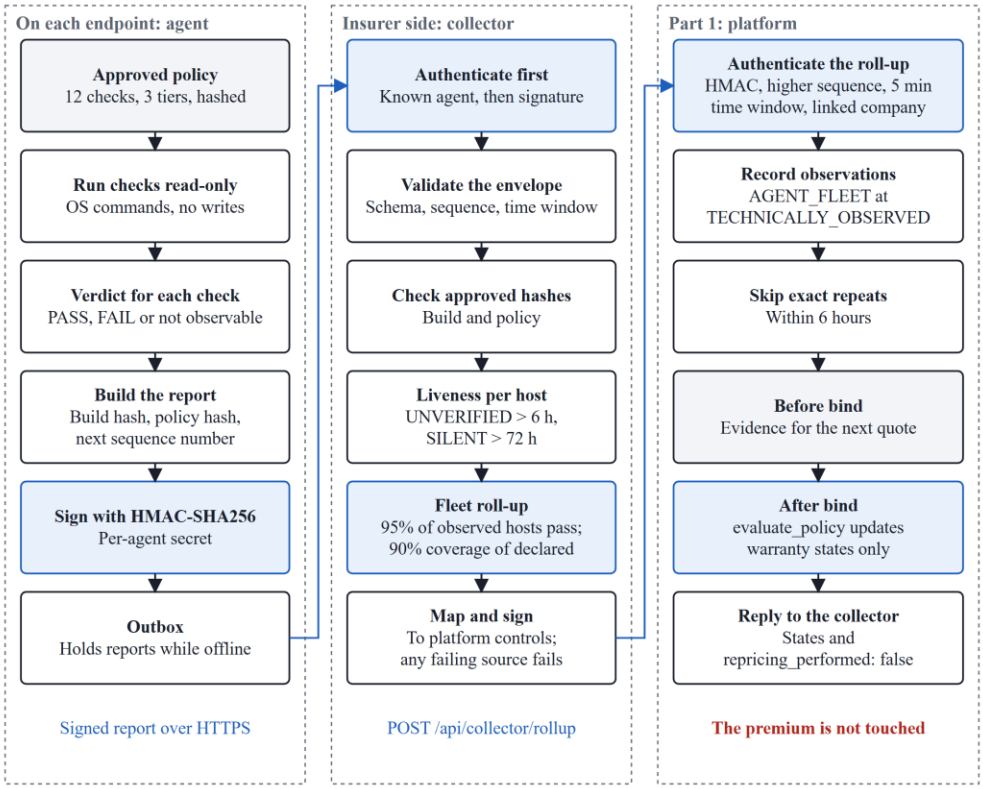


Fig. 4. Monitoring pipeline from agent to collector to platform

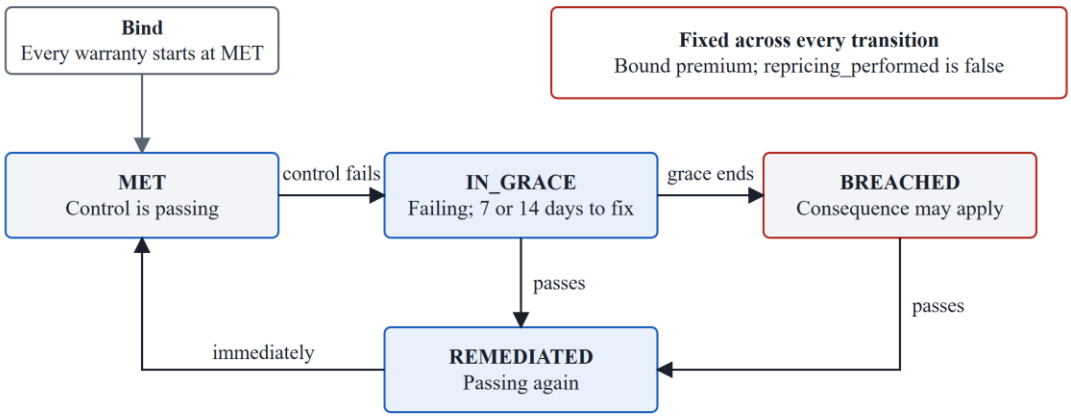


Fig. 5. Post-bind warranty state machine

V. Results and Analysis

All premium figures in this section exclude GST unless stated otherwise.

A. Automated Tests

All suites were run on the current code and all passed (Table VI). The V2 suite checks centring of every control, monotonicity in evidence, turnover, retention and limit, continuity across turnover zones, the payout against the closed-form LEV to within 0.1%, peril reconciliation, gating, referral, no re-pricing after bind, and reproduction of stored V1 and V2 quotes. Section III-K maps the suites to test levels.

TABLE VI
Automated Test Results

Suite	Tests	Result
Part 1: platform, fleet link and pricing V2	65	All pass
Part 2: agent, collector, HTTPS end to end	158	All pass
Integration: both systems running together	1	Passes
Total	**224**	**All pass**

B. Effect of Evidence Strength

Table VII prices the reference firm with all 12 priced controls at each status. The same firm with the same claimed controls pays 19% more when they are stated than when they

are verified, and 5.34 times as much when none is evidenced. All-NOT_WORKING gives the same figure as all-UNKNOWN, by design. Ransomware reaches the 0.27 floor when all controls are verified and the 3.0 ceiling when none is evidenced.

TABLE VII
REFERENCE FIRM BY EVIDENCE STATUS (₹)

All controls	Expected loss	Technical premium	Payable with GST	Gate outcome
VERIFIED	23,244	46,487	54,855	Eligible
STATED	27,671	55,342	65,304	Conditionally eligible
UNKNOWN	1,24,117	2,48,235	2,92,917	Ineligible; referral triggered

In the all-verified case, FTF accounts for 64% of expected loss (₹14,927 of ₹23,244). Only the credential-stage controls act on FTF, and in this model it is not sub-limited. The payment verification that would most directly reduce it is not priced, because no centred effect has been published.

C. Value of Verifying One Control

Table VIII starts from the all-STATED firm and changes one control. Verifying PAM saves 6.8% and vulnerability management 6.4%; both have low adoption, which widens the gap between holding and lacking them. Encryption hardly moves the premium, since it acts only on the small other first-party and third-party severities. The same what-if calculation appears on each quote.

TABLE VIII
CHANGE IN TECHNICAL PREMIUM FROM THE ALL-STATED BASE OF ₹55,342

Control	Verified	Not working
Privileged access management	−6.8%	+20.7%
Vulnerability management	−6.4%	+14.7%
Email security	−5.1%	+45.6%
Multi-factor authentication	−3.9%	+32.7%
Tested backups	−2.7%	+9.8%
Awareness	−2.0%	+74.7%
Critical patching	−1.2%	+4.6%
Endpoint detection and response	−1.0%	+31.8%
Incident-response plan	−0.7%	+2.7%
Secure configuration	−0.6%	+36.5%
Logging and monitoring	−0.4%	+34.0%
Encryption	−0.02%	+0.06%

D. Turnover, Sector, Policy Structure and Claims

Table IX gives the remaining one-input changes, with all controls STATED. The transition zone works as intended near the boundary: around ₹220 crore (USD 25 million), each extra ₹10 lakh of turnover adds about ₹200. The zone only smooths the step, and the premium still rises 4.9 times between ₹176 crore and ₹275 crore. The cause is the source data, where claim frequency goes from 1.19% to 3.99% between bands. Such a sharp change for a modest growth in size would need review on a real book.

TABLE IX
TECHNICAL PREMIUM UNDER ONE-INPUT CHANGES (₹)

Input	Value: premium
Turnover (crore)	5: 49,787; 88: 52,491; 150: 55,342; 220: 1,23,242; 275 to 700: 2,70,908; 880: 3,87,049; 1,100 to 2,000: 5,48,564
Sector (NIC)	Financial (64): 47,057; Retail (47): 50,249; Unmapped: 54,663; IT (62): 55,342; Manufacturing (28): 56,460; Healthcare (86): 60,241; Education (85): 62,665
Retention (lakh)	1: 58,528; 5: 55,342; 10: 52,460; 25: 46,509; 50: 40,171
Limit (crore)	1: 27,722; 2.5: 42,684; 5: 55,342; 10: 68,056; 25: 83,212
Material incidents	0: 55,342 (×0.995); 1: 68,456 (×1.231); 2: 81,570 (×1.466, referral); 3: 94,685 (×1.702, referral)

Doubling the limit raises the premium by far less than double, since a lognormal severity puts most claims below the limit. Going from ₹5 crore to ₹25 crore still adds 50%, which is consistent with the heavy tails reported in the literature [10], [11].

E. Worked Example With Mixed Evidence

Table X prices a firm with mixed evidence: patching, secure configuration, logging and encryption verified; EDR not working; PAM unknown; the rest stated; and one material incident. The largest saving on the quote is verifying PAM at ₹32,421. The quote is ineligible under the default gate because EDR is not working, and that gate outcome has no effect on the premium.

TABLE X
WORKED EXAMPLE: STEP-BY-STEP ENGINE OUTPUT

Step	Result
Classification	Turnover: frequency ×0.804, severity ×0.687. Sector: frequency ×0.919, severity ×1.141
Ransomware controls	Weakness ×0.609, execution ×2.013, credential ×0.885; combined ×1.085
Claims multiplier	(4.22 + 1) / (4.22 + 0.0099 × 3) = ×1.228
Expected loss by peril	Ransomware ₹20,823; FTF ₹20,287; BEC ₹5,379; other first-party ₹3,277; third-party ₹181; total ₹49,947
Premium	Technical ₹99,895; GST ₹17,981; payable ₹1,17,876
Gate	Ineligible: EDR not working (binding blocked)
Largest savings	Verify PAM ₹32,421; fix and verify EDR ₹20,877; verify vulnerability management ₹12,739

F. Sensitivity to Assumptions

Table XI moves each assumption to its low and high values for the worked-example firm. The largest effects are from σ, damping β, the credit x and the TLR, each of which moves the premium by more than 10% in at least one direction. A lower σ raises the premium because, with the mean fixed, less of the loss lies beyond the limit. The placeholder head shares have almost no effect, so their missing source barely affects the premium.

TABLE XI
SENSITIVITY OF THE WORKED EXAMPLE (BASE ₹99,895)

Assumption	Low	Change	High	Change
Lognormal shape σ	1.97	+16.3%	2.19	+0.2%
Within-stage damping β	0	+8.2%	1	−15.5%
Credit for STATED x	0.4	+13.2%	0.8	−12.6%
Target loss ratio	0.48	+4.2%	0.57	−12.3%
Trend	−10%	−10.0%	+10%	+10.0%
Credibility α	3.45	+4.1%	6.94	−7.3%
Zone factor	1.10	0.0%	1.50	+4.5%
USD/INR rate	83	−4.1%	92	+3.2%
MFA adoption	0.5	−3.1%	0.9	+1.4%
Control caps	[0.5, 2.0]	base	[0.4, 2.5]	−1.5%
Head-share placeholders	×0.75	+0.1%	×1.25	−0.1%

G. Cross-system Run on SIMULATED Endpoints

The integration test starts both systems and four endpoints whose data is labelled SIMULATED. Before bind, the roll-up reaches the platform as AGENT_FLEET evidence, and the quote reads EDR as VERIFIED. Backups read as STATED, because a recent backup is observable from a host but a restore test is not. MFA is not sent. After bind, stopping EDR on one of the four machines takes the warranty from MET to IN_GRACE. Restoring it produces the recorded path MET, IN_GRACE, REMEDIATED, MET, and the bound premium is equal at each check. The collector dashboard shows the platform's state for the linked company. The run does not measure detection accuracy on real machines.

VI. ADVANTAGES, LIMITATIONS AND APPLICATIONS

A. Advantages

- Each premium can be traced from its factors to their sources, and each quote lists the assumptions it relied on.
- The what-if list gives a firm the rupee saving from verifying each control.
- A stored snapshot reproduces an old quote exactly, even after the parameters change.
- The insured gains no pricing benefit from withholding evidence, and monitoring cannot produce a surprise premium change during the term.
- With no third-party runtime packages, the code can be audited in full.

B. Limitations

- The frequencies and severities come from US-weighted claims books and the India factors are set to 1. The USD/INR rate of 88 is a placeholder. The premiums are not validated rates for the Indian market.
- Parameters were entered from the project's model specification. Their figure-level locators have not all been re-checked against the source reports, and several values remain tagged [A], including MFA adoption, most head shares and severity adoption.
- Base frequencies come from Coalition's book and adoption rates from Marsh's clients. If Marsh's clients have better controls, the average firm may be underpriced.
- Turnover and sector effects are assumed equal across perils, and one σ is shared by all perils.
- Accumulation is not modelled and clustering of attacks, as studied by Bessy-Roland, Boumezoued and Hillairet [17], is ignored. Accumulation risk sits inside the 20% margin.
- There are no per-cover sub-limits, whereas a real wording would usually limit some covers, such as FTF, which would lower the premium.
- The results use simulated endpoints. The Windows checks are unit-tested on recorded command output, and their run on a real Windows machine remains an open item. MFA and restore tests cannot be observed from an endpoint.
- A legacy single-host endpoint on the platform still accepts unsigned reports and must be disabled before any real use. Grace periods are whole days, so demonstrations use an audited fast-forward.

C. Applications

- Students and researchers can read how a cyber premium is built and rerun it with other parameters.
- An insurer could build an evidence-graded SME product from it, once the parameters are recalibrated on Indian claims and the model passes actuarial validation and regulatory review.
- An SME can rank its controls by how much each reduces modelled loss.

VII. CONCLUSION AND FUTURE SCOPE

Beretta shows that evidence grading, published claims data, explainable pricing and signed post-bind monitoring can operate as one open pipeline, with monitoring kept away from the premium. For one reference firm, moving from no evidence to verified controls lowers the modelled premium from ₹2,48,235 to ₹46,487, and each step of that difference can be traced to a named factor and source. All 224 tests pass, and a cross-system run on SIMULATED endpoints holds the bound premium constant through a warranty failure and recovery.

The next steps are to re-check every parameter against its source report and replace the [A] values where possible; set the India factors from Indian claims data as it becomes available; run the Windows checks on real machines and measure false-result rates; add identity-provider connectors so that MFA can be verified; model accumulation and attack clustering; and strengthen tamper resistance and update signing in the agent. The model also still needs back-testing on a real claims book.

REFERENCES

[1] GlobalData, "Cyber insurance gap leaves SMEs dangerously exposed to cyberattacks," press release, 2025.

[2] Government of India, *The Digital Personal Data Protection Act, 2023*, Act No. 22 of 2023, Aug. 2023.

[3] Indian Computer Emergency Response Team, *Directions under sub-section (6) of section 70B of the Information Technology Act, 2000*, No. 20(3)/2022-CERT-In, New Delhi, India, Apr. 28, 2022.

[4] S. Romanosky, L. Ablon, A. Kuehn, and T. Jones, "Content analysis of cyber insurance policies: How do carriers price cyber risk?" *Journal of Cybersecurity*, vol. 5, no. 1, art. tyz002, Jan. 2019, doi: 10.1093/cybsec/tyz002.

[5] D. Woods, I. Agrafiotis, J. R. C. Nurse, and S. Creese, "Mapping the coverage of security controls in cyber insurance proposal forms," *Journal of Internet Services and Applications*, vol. 8, no. 1, art. 8, Dec. 2017, doi: 10.1186/s13174-017-0059-y.

[6] N. Shetty, G. Schwartz, M. Felegyhazi, and J. Walrand, "Competitive cyber-insurance and Internet security," in *Economics of Information Security and Privacy*. Boston, MA, USA: Springer, 2010, pp. 229–247, doi: 10.1007/978-1-4419-6967-5_12.

[7] R. Böhme and G. Schwartz, "Modeling cyber-insurance: Towards a unifying framework," in *Proc. Workshop on the Economics of Information Security (WEIS)*, Cambridge, MA, USA, Jun. 2010.

[8] A. Marotta, F. Martinelli, S. Nanni, A. Orlando, and A. Yautsiukhin, "Cyber-insurance survey," *Computer Science Review*, vol. 24, pp. 35–61, May 2017, doi: 10.1016/j.cosrev.2017.01.001.

[9] R. Pal, L. Golubchik, K. Psounis, and P. Hui, "Will cyber-insurance improve network security? A market analysis," in *Proc. IEEE INFOCOM*, Toronto, ON, Canada, Apr. 2014, pp. 235–243, doi: 10.1109/INFOCOM.2014.6847944.

[10] T. Maillart and D. Sornette, "Heavy-tailed distribution of cyber-risks," *The European Physical Journal B*, vol. 75, no. 3, pp. 357–364, Jun. 2010, doi: 10.1140/epjb/e2010-00120-8.

[11] B. Edwards, S. Hofmeyr, and S. Forrest, "Hype and heavy tails: A closer look at data breaches," *Journal of Cybersecurity*, vol. 2, no. 1, pp. 3–14, Dec. 2016, doi: 10.1093/cybsec/tyw003.

[12] C. Biener, M. Eling, and J. H. Wirfs, "Insurability of cyber risk: An empirical analysis," *The Geneva Papers on Risk and Insurance: Issues and Practice*, vol. 40, no. 1, pp. 131–158, Jan. 2015, doi: 10.1057/gpp.2014.19.

[13] M. Eling and N. Loperfido, "Data breaches: Goodness of fit, pricing, and risk measurement," *Insurance: Mathematics and Economics*, vol. 75, pp. 126–136, Jul. 2017, doi: 10.1016/j.insmatheco.2017.05.008.

[14] M. Eling and J. Wirfs, "What are the actual costs of cyber risk events?" *European Journal of Operational Research*, vol. 272, no. 3, pp. 1109–1119, Feb. 2019, doi: 10.1016/j.ejor.2018.07.021.

[15] M. Xu and L. Hua, "Cybersecurity insurance: Modeling and pricing," *North American Actuarial Journal*, vol. 23, no. 2, pp. 220–249, Apr. 2019, doi: 10.1080/10920277.2019.1566076.

[16] G. Zeller and M. Scherer, "A comprehensive model for cyber risk based on marked point processes and its application to insurance," *European Actuarial Journal*, vol. 12, no. 1, pp. 33–85, Jun. 2022, doi: 10.1007/s13385-021-00290-1.

[17] Y. Bessy-Roland, A. Boumezoued, and C. Hillairet, "Multivariate Hawkes process for cyber insurance," *Annals of Actuarial Science*, vol. 15, no. 1, pp. 14–39, Mar. 2021, doi: 10.1017/S1748499520000093.

[18] Q. Xiang, A. Neufeld, G. W. Peters, I. Nevat, and A. Datta, "A bonus-malus framework for cyber risk insurance and optimal cybersecurity provisioning," *European Actuarial Journal*, vol. 14, no. 2, pp. 581–621, Aug. 2024, doi: 10.1007/s13385-023-00366-0.

[19] H. Bühlmann, "Experience rating and credibility," *ASTIN Bulletin*, vol. 4, no. 3, pp. 199–207, Jul. 1967, doi: 10.1017/S0515036100008989.

[20] S. A. Klugman, H. H. Panjer, and G. E. Willmot, *Loss Models: From Data to Decisions*, 5th ed. Hoboken, NJ, USA: Wiley, 2019.

[21] J. R. C. Nurse, L. Axon, A. Erola, I. Agrafiotis, M. Goldsmith, and S. Creese, "The data that drives cyber insurance: A study into the underwriting and claims processes," in *Proc. Int. Conf. Cyber Situational Awareness, Data Analytics and Assessment (CyberSA)*, Jun. 2020, pp. 1–8, doi: 10.1109/CyberSA49311.2020.9139703.

[22] G. Mott, S. Turner, J. R. C. Nurse, J. MacColl, J. Sullivan, A. Cartwright, and E. Cartwright, "Between a rock and a hard(ening) place: Cyber insurance in the ransomware era," *Computers & Security*, vol. 128, art. 103162, May 2023, doi: 10.1016/j.cose.2023.103162.

[23] D. Woods and A. Simpson, "Policy measures and cyber insurance: A framework," *Journal of Cyber Policy*, vol. 2, no. 2, pp. 209–226, May 2017, doi: 10.1080/23738871.2017.1360927.

[24] D. W. Woods and T. Moore, "Does insurance have a future in governing cybersecurity?" *IEEE Security & Privacy*, vol. 18, no. 1, pp. 21–27, Jan. 2020, doi: 10.1109/MSEC.2019.2935702.

[25] S. Dambra, L. Bilge, and D. Balzarotti, "SoK: Cyber insurance – Technical challenges and a system security roadmap," in *Proc. IEEE Symposium on Security and Privacy (SP)*, San Francisco, CA, USA, May 2020, pp. 1367–1383, doi: 10.1109/SP40000.2020.00019.

[26] K. Dempsey, N. S. Chawla, A. Johnson, R. Johnston, A. C. Jones, A. Orebaugh, M. Scholl, and K. Stine, "Information security continuous monitoring (ISCM) for federal information systems and organizations," National Institute of Standards and Technology, Gaithersburg, MD, USA, NIST SP 800-137, Sep. 2011.

[27] F. Doshi-Velez and B. Kim, "Towards a rigorous science of interpretable machine learning," arXiv:1702.08608, 2017.

[28] Coalition, Inc., *2025 Cyber Claims Report*. San Francisco, CA, USA: Coalition, 2025.

[29] Cyentia Institute, *Information Risk Insights Study (IRIS) 2025*. Cyentia Institute, 2025.

[30] NetDiligence, *Cyber Claims Study 2025*. Gladwyne, PA, USA: NetDiligence, 2025.

[31] Marsh McLennan, *Using Data to Prioritize Cybersecurity Investments*. New York, NY, USA: Marsh McLennan, 2023.

[32] Sophos, *The Impact of Compromised Backups on Ransomware Outcomes*. Abingdon, U.K.: Sophos, 2024.

[33] IBM Security and Ponemon Institute, *Cost of a Data Breach Report 2023*. Armonk, NY, USA: IBM, 2023.

[34] IBM Security and Ponemon Institute, *Cost of a Data Breach Report 2019*. Armonk, NY, USA: IBM, 2019.

[35] L. A. Meyer, S. Romero, G. Bertoli, T. Burt, A. Weinert, and J. L. Ferres, "How effective is multifactor authentication at deterring cyberattacks?" arXiv:2305.00945, 2023.

[36] Cyentia Institute, *Information Risk Insights Study (IRIS) 2022*. Cyentia Institute, 2022.

[37] Fitch Ratings, US standalone cyber insurance loss ratios, as reported in *Insurance Journal*, May 2024.

[38] National Association of Insurance Commissioners, *Report on the Cybersecurity Insurance Market*. Kansas City, MO, USA: NAIC, 2026.

[39] Insurance Regulatory and Development Authority of India, *IRDAI (Expenses of Management of Insurers transacting General or Health Insurance Business) Regulations, 2023*, Hyderabad, India, 2023.

[40] H. Krawczyk, M. Bellare, and R. Canetti, "HMAC: Keyed-hashing for message authentication," IETF, RFC 2104, Feb. 1997.

[41] *IEEE Standard for Information Technology—Systems Design—Software Design Descriptions*, IEEE Std 1016-2009, Jul. 2009, doi: 10.1109/IEEESTD.2009.5167255.

[42] *Software and Systems Engineering—Software Testing—Part 1: General Concepts*, ISO/IEC/IEEE 29119-1:2022, 2022.

[43] *IEEE Standard for Floating-Point Arithmetic*, IEEE Std 754-2019, Jul. 2019.

[44] National Institute of Standards and Technology, *Secure Hash Standard (SHS)*, FIPS PUB 180-4, Aug. 2015.

[45] T. Dierks and E. Rescorla, "The Transport Layer Security (TLS) protocol version 1.2," IETF, RFC 5246, Aug. 2008.